

Verifai GRC - Razorpay Payment Integration

Complete Guide to Autopay Subscriptions

1. Overview

This document explains how Verifai GRC handles recurring payments using **Razorpay Subscriptions API** with mandate-based autopay.

What We Use

Component	Technology
Payment Gateway	Razorpay
API	Razorpay Subscriptions API
Method	Mandate-based recurring payments
Trial Period	14 days (configurable via <code>TRIAL_DAYS</code> env)

Supported Payment Methods

Method	Description
UPI AutoPay	Customer authorizes via UPI apps (GPay, PhonePe, Paytm, BHIM)
e-NACH	Electronic National Automated Clearing House - bank mandate
Card Mandate	Visa/Mastercard recurring authorization

2. Subscription Pricing Structure

2-Year Mandatory Contract

Period	Duration	Price per Module	Description
Trial	14 days	FREE	Full platform access
Year 1	12 months	₹1,200/year	Promotional "BASE" plan
Year 2	12 months	₹1,80,000/year	Standard "GENERAL" plan

Total 2-Year Cost per Module: ₹1,81,200 + GST (18%) = **₹2,13,816**

3. The Complete Payment Flow

Step 1: Customer Signs Up (Day 1)

1. Customer fills signup form with organization details
2. Selects modules (GRC, TPRM, Internal Audit)
3. Agrees to 2-year contract and autopay terms
4. Razorpay checkout opens
5. Customer authorizes the mandate via UPI/Card/Bank
6. **Mandate status:** authenticated
7. **Trial begins immediately**

Step 2: Trial Period (Day 1-14)

- Customer has **full access** to all selected modules
- **No charges are made**
- Mandate is authorized but not yet used for payment

Step 3: First Automatic Payment (Day 15)

What happens automatically:

1. Razorpay initiates charge using the stored mandate
2. Customer's bank processes payment automatically
3. Customer does NOT need to take any action

If payment succeeds:

- Invoice marked as `PAID`
- Subscription status → `ACTIVE`
- Mandate status → `active`
- Customer continues using platform

If payment fails:

- Razorpay retries automatically (Razorpay's retry schedule)
- If ALL retries fail → `subscription.halted` event fired
- See Section 5 for what happens next

Step 4: Year 2 Renewal (Day 380)

- Razorpay automatically charges Year 2 amount
- Same process as Day 15 payment

4. Mandate Status States

Status	Meaning	Customer Access
<code>pending</code>	Awaiting customer authorization	No access
<code>created</code>	Mandate created, not yet authorized	No access
<code>authenticated</code>	Mandate authorized, trial active	Full access
<code>active</code>	Payment captured, subscription running	Full access
<code>halted</code>	Payment failed after all retries	ACCESS REVOKED
<code>cancelled</code>	Cancelled by customer or admin	ACCESS REVOKED
<code>completed</code>	All scheduled charges completed	Access until expiry

5. What Happens When Payment Fails

Scenario A: Payment Fails, Retries Succeed

If payment fails but a retry succeeds:

- Invoice marked `PAID`
- Subscription continues normally
- No action needed from customer

Scenario B: All Retries Exhausted (subscription.halted)

This is what our code does when Razorpay sends `subscription.halted` :

```
1. mandateStatus → "halted"
2. cancelledAt → current timestamp
3. Subscription status → "SUSPENDED"
4. autoRenew → false
5. All DRAFT/ISSUED invoices → "FAILED"
6. Module access flags disabled:
  - isGrcAdded → false
  - isTprmAdded → false
  - isInternalAuditEnabled → false
7. Customer LOSES ACCESS immediately
```

From our code (`subscription/route.ts` line 236-299):

"CRITICAL: Autopay failed - IMMEDIATELY end subscription. The 2-year contract requires working autopay. If it fails, subscription ends."

6. What Happens When Customer Disables Autopay

If a customer disables autopay from their banking app (UPI/bank settings), Razorpay sends `subscription.paused` event.

Our implementation treats this as termination:

1. mandateStatus → "cancelled"
2. cancelledAt → current timestamp
3. Subscription status → "SUSPENDED"
4. autoRenew → false
5. Customer LOSES ACCESS immediately

From our code (`subscription/route.ts` line 344-367):

"Subscription paused - treat as terminated (autopay disabled)"

WHY: The 2-year contract requires valid autopay authorization. If customer disables it, they are breaking the contract terms.

7. Webhook Events We Handle

Our webhook endpoint: `/api/webhooks/razorpay/subscription`

Event	When It Fires	What We Do
<code>subscription.authenticated</code>	Customer authorizes mandate	Enable trial, set status "authenticated"
<code>subscription.charged</code>	Payment captured successfully	Mark invoice PAID, status "active"
<code>subscription.halted</code>	All payment retries failed	SUSPEND immediately , revoke access
<code>subscription.paused</code>	Customer disabled autopay	SUSPEND immediately , revoke access
<code>subscription.cancelled</code>	Cancelled by admin/customer	End subscription, revoke access
<code>subscription.completed</code>	All charges done (2 years)	Mark as completed
<code>subscription.pending</code>	Awaiting authorization	Set status "pending"

8. Security Implementation

Signature Verification

Every webhook from Razorpay is verified using:

- **HMAC-SHA256** signature
- **Timing-safe comparison** (`crypto.timingSafeEqual`) to prevent timing attacks
- Raw body used for signature calculation

Fail-Closed Security

In production, if `RAZORPAY_WEBHOOK_SECRET` is not configured:

- Webhook is **REJECTED** (not accepted)
- This prevents processing of forged requests

Payload Validation

All webhook payloads validated with **Zod schemas** before processing.

Idempotency

Each webhook event ID is stored in `RazorpayEvent` table:

- Duplicate events are ignored
- Prevents double-processing

9. Key Code Files

File	Purpose
<code>src/lib/payment-provider-mandate.ts</code>	Create/manage subscription mandates
<code>src/lib/payment-provider.ts</code>	Signature verification, Razorpay client
<code>src/lib/razorpay-plan-manager.ts</code>	Manage Razorpay plans
<code>src/app/api/webhooks/razorpay/subscription/route.ts</code>	Subscription webhook handler

10. Environment Variables

```

RAZORPAY_KEY_ID=rzp_live_XXXXX
RAZORPAY_KEY_SECRET=XXXXX      # Never expose publicly
RAZORPAY_WEBHOOK_SECRET=XXXXX
PAYMENT_STUB=false             # true for testing without real payments
TRIAL_DAYS=14                  # Trial period duration

```

11. Database Tables

Table	Purpose
<code>ModuleSubscription</code>	Links modules to Razorpay mandate IDs
<code>Subscription</code>	Customer subscription records
<code>Invoice</code>	Billing records (DRAFT, ISSUED, PAID, FAILED)
<code>Payment</code>	Payment transaction records
<code>RazorpayEvent</code>	Webhook idempotency tracking
<code>RazorpayPlan</code>	Cached Razorpay plan IDs

12. Summary: Critical Rules

1. **Payment Method:** Razorpay Subscriptions API with mandate (UPI AutoPay / e-NACH / Card)
 2. **Trial:** 14 days free, then autopay charges automatically
 3. **If payment fails completely:** Subscription SUSPENDED immediately, access revoked
 4. **If customer disables autopay:** Treated as contract breach, subscription SUSPENDED immediately
 5. **No grace period:** Our implementation does not have a grace period - failure = immediate suspension
 6. **2-year commitment:** Contract requires working autopay for entire duration
-

Document Version: 1.0 | Based on actual code implementation